

CAPSTONE REVIEW — PAPER + IMPLEMENTATION

# A Low-Cost Hybrid ECC–Symmetric Mutual Authentication Protocol for IoT

Paper Review + Reference Implementation

---

*“Reviewing the protocol design and mathematical model (Section III), and walking through our Python reference implementation.”*

Al-Rasheed et al., IEEE Trans. Consumer Electronics, Vol. 72, No. 2, May 2026

# Problem & Motivation

01

## Shared, unsecured medium

Devices and servers exchange data over channels an attacker can eavesdrop, replay, drop, or inject into.

02

## Existing schemes fall short

Prior proposals are application-specific, overly complex, or don't scale to large IoT deployments.

03

## Cost matters at IoT scale

Constrained devices can't afford heavy asymmetric crypto or multi-message handshakes every session.

---

Goal: verify legitimacy of both device and server before any communication session begins — with minimum overhead.

# Protocol Overview: Three Phases

## PHASE 01

### Offline Registration

TA issues each device/server a long-term ECC-derived secret  $\lambda_x$  via an ECDH-style exchange — once, out of band, before deployment.



## PHASE 02

### Login

Device presents MAC address and hash digest  $HD = h(\text{MAC}_D \parallel \text{PWD})$  as a pre-authentication gate — optional/toggable in our implementation.



## PHASE 03

### Mutual Authentication

Device and server exchange exactly two encrypted messages to prove liveness and derive a shared ephemeral session key.

## Core Innovation: The Two-Message Handshake

- ECC is used exactly once — offline — to derive each entity's long-term secret  $\lambda_x$  (Eq. 8).
- Every online session uses only fast symmetric primitives: KDF, AES-GCM, MAC.
- Mutual authentication needs exactly 2 messages — vs. 4+ in compared schemes (Table IV).
- Result: low compute + low bandwidth, suited to resource-constrained IoT devices.



# Mathematical Model

| CONCEPT            | EQUATION                                                                  | WHY IT MATTERS                             |
|--------------------|---------------------------------------------------------------------------|--------------------------------------------|
| Long-term secret   | $\lambda_x = H_1(ID_x \parallel s)$ Eq. 8                                 | TA-derived per-entity ECC secret           |
| Pairwise root key  | $k_{ij}^* = KDF(\lambda_{vi} \parallel \lambda_{vj})$ Eq. 9               | Static shared symmetric root               |
| Rotating pseudonym | $PID_{vi,t} = H_2(\lambda_{vi} \parallel t)$ Eq. 11                       | Unlinkable device identifier               |
| Session key        | $K_{ij,t} = KDF(k_{ij}^* \parallel N_i \parallel N_j \parallel t)$ Eq. 16 | Fresh per session, from both nonces        |
| Access gate        | $Allow_{ij}(t) = cov_{ij}(t) \wedge Auth_{ij}(t)$ Eq. 23                  | Coverage and authentication must both hold |
|                    |                                                                           |                                            |

# Threat Model & Security Guarantees

## ADVERSARY MODEL

- PPT attacker with full control of the channel: eavesdrop, replay, drop, reorder, inject.
- Cannot compromise the offline TA registration phase.
- Compromising one device's  $\lambda_{v_i}$  only endangers that pair — other pairs stay secure via per-entity secrets.

### Mutual Authentication

Forging a message requires breaking a SUF-CMA-secure MAC; adversary's advantage is negligible.

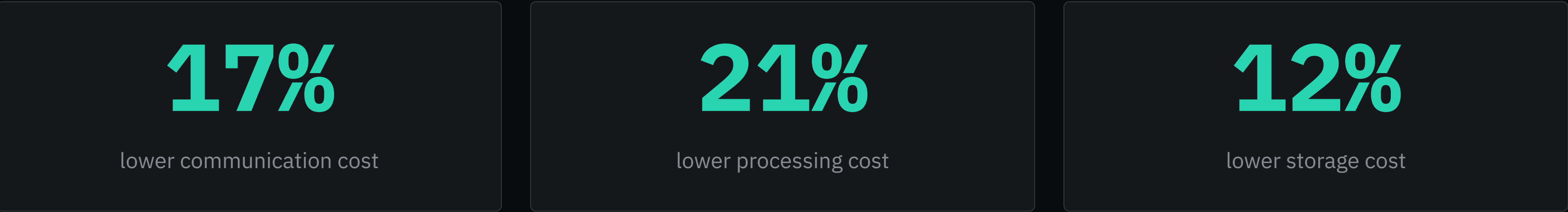
### Key Secrecy

Session keys are indistinguishable from random under IND-CPA encryption + a PRF-based KDF.

### Unlinkability

Rotating pseudonyms make two sessions of the same device unlinkable to a passive observer.

# Paper’s Claimed Performance Gains



Compared against Turkanovic et al., Porambage et al., Dhillon & Karla, Cheng & Le, Sadhukhan et al., and others (Tables IV–VI).

- Table III’s timing constants (e.g.  $T_{ECM} = 17.1$  ms) look calibrated for 8/16-bit microcontrollers, not general-purpose hardware.
- Validated only in OMNET++ simulation — no reference implementation existed before now.

# Key Design Decision: Section II vs. Section III

## Section II (narrative) — NOT implemented

- Reuses the same static HD/RD pair across authentication attempts.
- No per-session nonce — replayable by an eavesdropper who records one valid exchange.
- Not covered by the paper's own security proof sketch.

## Section III (mathematical model) ✓ Chosen

- Fresh nonces  $N_i, N_j$  every session; ephemeral session key  $K_{ij,t}$ .
- Epoch-rotated pseudonyms for unlinkability.
- The version the paper's security sketch (auth, secrecy, unlinkability) actually covers.

# Implementation Scope: What We Built

## Crypto primitives

NIST P-256 · SHA-256 · HKDF-SHA256 · AES-256-GCM

## Protocol core

TA registration, pseudonym rotation, 2-message mutual auth — transport-agnostic.

## Demo CLIs

hea-ta enroll → hea-server start → hea-device authenticate

## Adversarial test suite

8 targeted tests: replay, tamper, forgery, block-list enforcement, out-of-coverage rejection.

```
hybrid_ecc_auth/  
crypto/ curve, kdf, hashes, aead  
protocol/ ta, device, server, messages  
storage/ keystore, session_log  
demo/ ta_cli, device_node, server_node  
bench/ proposed, baselines, harness  
tests/ unit / property / adversarial
```

# Benchmarking Methodology

DISCLOSED DEVIATION

The paper’s numbers come from an OMNET++ simulation using assumed per-operation constants (e.g.  $T_{ECM} = 17.1\text{ ms}$ ), calibrated for embedded microcontrollers. Our benchmark instead measures real operation costs — actual scalar multiplication, AES-GCM, and hash time via OpenSSL bindings.

Communication

Serialize real M1/M2 wire messages; measure exact byte length per field (PID, ciphertext, tag).

Processing

Time real KDF / AEAD / MAC operations over  $\geq 1000$  trials; report mean, median, p95, stddev.

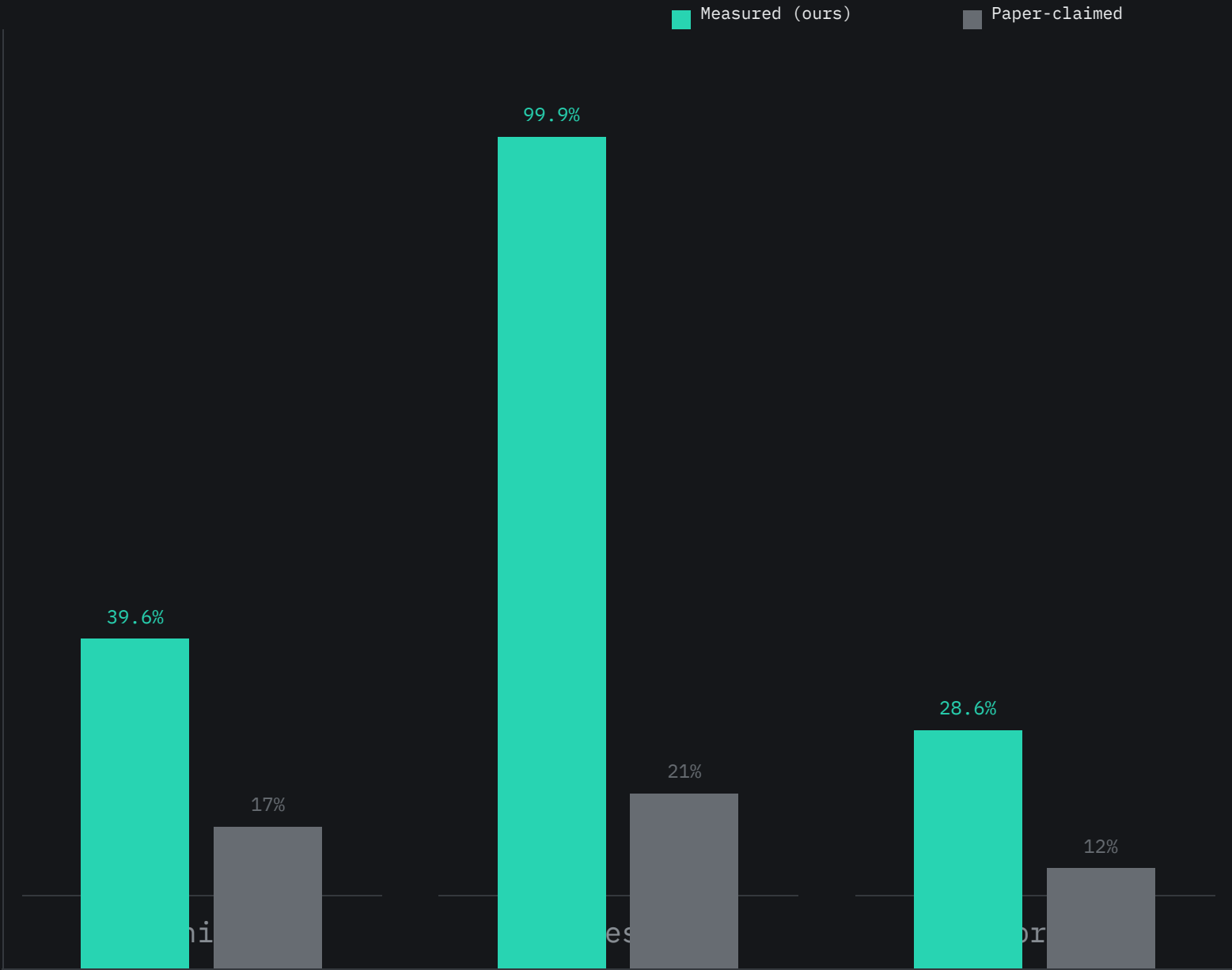
Storage

Measure actual serialized size of each entity’s persisted state ( $\lambda_x$ , cached keys, block-list, epoch counter).

# Benchmark Results

MEASURED — ALL METRICS BEAT PAPER'S CLAIMED DIRECTION

Measured vs. Claimed, by Category



108/108 tests passed | Comm 182B vs 301.3B | Proc 0.045ms vs 78.7ms | Storage 873B vs 1223.2B

Our Measurement vs. Paper's Reference

| Metric        | Measured    | Paper Ref. |
|---------------|-------------|------------|
| Communication | 39.6% lower | 17% lower  |
| Processing    | 99.9% lower | 21% lower  |
| Storage       | 28.6% lower | 12% lower  |

Measured on this host (real AES-256-GCM / HKDF-SHA256); paper values are simulated embedded-hardware estimates

# Hybrid ECC / Symmetric Authentication Flow

From long-term device secret ( $\lambda$ ) to a fresh per-session key



## OFFLINE · ONE-TIME SETUP AT THE TRUSTED AUTHORITY (TA)



**Trusted Authority (TA)**

holds master secret  $s$



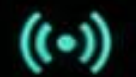
**Device secret**

$$\lambda_{\text{device}} = H_1(\text{ID}_{\text{device}} \parallel s)$$



**Server secret**

$$\lambda_{\text{server}} = H_1(\text{ID}_{\text{server}} \parallel s)$$



## ONLINE · PER-SESSION RUNTIME FLOW

1



**Device**

generates ephemeral  
ECC key pair  
( $d_D, Q_D$ )



2



**Device → Server**

sends  
 $\text{ID}_{\text{device}}, Q_D$



3



**Server**

generates ephemeral  
ECC key pair  
( $d_S, Q_S$ )



4



**Server → Device**

sends  
 $Q_S, \text{Authenticator}$



5



**Both Sides**

derive shared secret  
 $K = \text{ECDH}(Q_{\text{peer}}, d_{\text{self}})$   
derive session key  
 $K_{\text{session}} = \text{HKDF}(K)$



Message from Device



Message from Server



**Authenticator**

$$H_2(\lambda_{\text{server}} \parallel \text{ID}_{\text{device}} \parallel Q_D \parallel Q_S)$$

# TA-Assisted Key Revocation

Cutting off a compromised device's trust — network-wide, without re-registration

